ASSET VOYAGES BID · WEEKEND REVIEW PACK · V2 · 31 OCTOBER 2026

ASSET Voyages: website and Congress catalogue

Here's what I'm planning to build. Please tell me where I'm wrong.

1. What this is

Thank you both for doing this. I'm Debanjan, and I'm bidding solo (me plus an AI-assisted build workflow) for a French business-travel agency's new site: public pages, a structured Congress catalogue, an enquiry back-office and an editor console. It's a competitive consultation, nothing is signed, and it's bigger than anything I've shipped as one product: about 40% of the hours rest on code I've run in production; 60% is new. I'd much rather you break it now than the client does at acceptance. Please keep it to yourselves: the RFP is restricted to invited suppliers and this pack has my internal pricing.

Links (concept is noindex; nothing on it persists)

What	URL
Current client site (WordPress 6.9.11)	http://asset-voyagesdaffaires.com
My concept, home: film « Du brief au retour », offer cards, catalogue demo (12 fictional listings), three contact journeys	https://asset-voyages-redesign.pages.dev/
Pitch page: why it's shaped this way	https://asset-voyages-redesign.pages.dev/pour-asset/
Console mock-up (static; buttons show a toast)	https://asset-voyages-redesign.pages.dev/console/
The 30 questions I sent, with defaults	https://asset-voyages-redesign.pages.dev/questions/

What I need from you

1. Skim §2 (context). Read §3–§9 properly.
2. Score each section 1–10 with a comment on the sheet in §10. Rubric: 9–10 you'd approve it at work unchanged; 7–8 sound, minor gaps; 5–6 at least one gap likely to cause a slip, an acceptance defect or overrun; 3–4 you'd block it; 1–2 start again.
3. **Attack §6 (build plan and tests) and §7 (effort, timeline, price) hardest.** §5's "check me" table is the other place I'd expect to be wrong.
4. Put your own probability next to mine for each risk in §8. That's the single most useful thing you can give me.
5. Grade against the client's requirement and a one-person team, not a ten-person team. "Hire someone" is a legitimate finding.

Conventions: **Estimate** = derived, not measured. **Open:** = unverified or waiting on the client. Euros excluding VAT (HT).

2. The job

Client. ASSET Voyages, a business-travel agency in Issy-les-Moulineaux, member of the Selectour Affaires network (« agence de voyages d'Affaires à taille humaine »). Coordinator: Veena (centralises responses, runs business acceptance); management approves budget, scope, architecture, milestones and launch. Today's site runs WordPress 6.9.11 + Slider Revolution 6.2.18 on `asset-voyagesdaffaires.com`, while the RFP cites `www.assetvoyages.com` (Open: which domain, Q6). Its client area says « Connexion Traveldoo » whereas the RFP says Wondermiles (Open: Q23). Unknown: host, domain/DNS owner, URL count, traffic, trackers, CRM, enquiry volumes.

Activity	What it is	Conversion
Business Travel	Managed corporate travel; booking, policy, reporting, invoicing, 24/7 assistance	F01 travel review / account request
MICE	Group events from 10 people; dedicated project lead	F02 progressive brief
International congresses	Delegate travel to (often medical) congresses, incl. Air France–KLM GM&E preferential fares where ASSET holds the event code	F03 flight quote pre-filled with the congress

What the RFP (v0.4, 9 pp) demands. Outcomes: qualified enquiries in all three activities; Veena + a backup publish without a developer; keep SEO value and the old site up throughout; integration points without making launch depend on unconfirmed API/SSO. Ticketing stays outside the CMS. 12–18 weeks "indicative"; written approval per milestone.

Work packages	Milestones	Acceptance tests (launch blocked by security defect, data loss, failed form, code exposure, missing critical redirect)
L0 (mand.) audit, workshops, journeys; keep/replace CMS with cost case	**J0** kickoff, access inventory	**T01/T02** BT / MICE forms: errors, saved once, routed, acknowledged
L1 (mand.) design, CMS, French content, BT + MICE pages, forms, measurement, SEO migration, security, training	**J1** audit: architecture, SEO inventory, baseline, backlog	**T03** congress search, filters, sort, no-results · **T04** draft not public
L2 (mand.) Congress catalogue, search, workflow, permissions, CSV import/export, moderation	**J2** wireframes, mock-ups, design system	**T05** GM&E code invisible to public and unauthorised roles · **T06** pre-filled ticket enquiry saved + notified
L3 (opt.) Wondermiles feasibility, SSO/API	**J3** core site on staging	**T07** past-congress rule · **T08** client-area link, no local passwords · **T09** tracker refusal works
L4 (opt.) controlled AI ingestion, human approval, logs	**J4** catalogue tested · **J5** pre-launch: SEO migration, tests, training, rollback · **J6** stabilisation, handover	**T10** priority URLs redirect · **T11** keyboard + screen reader · **T12** responsive + performance · **T13** test restore · **T14** documented export · **T15** Veena publishes and edits alone

Other hard numbers: responsive at 320/375/768/1440; LCP ≤ 2.5 s, INP ≤ 200 ms, CLS ≤ 0.1 at p75; WCAG 2.2 AA; RPO 24 h / RTO 8 business hours; French at launch, FR+EN architecture, no unapproved machine translation; GM&E codes never in HTML, scripts, public responses, exports or browser; accounts and data under ASSET's control; "team" and handover are assessment criteria.

Scope at a glance. Pages: home (3 activity cards, approved-claims strip, next 6 published congresses, client-area link), Business Travel, SMEs, procurement/travel managers, assistance (only register-confirmed services), digital solutions (approved Wondermiles text, demo CTA, configurable client-area button), MICE hub + 3 sub-pages, congress catalogue, agency/resources/articles/FAQ, contact (three doors) + 3 legal: ≈ 20 pages from ≈ 8 templates and ≈ 15 components. Journeys: SME owner → F01 "SME account"; travel manager → F01 "travel review"; HR/comms → F02 (3–4 steps + summary, back keeps data); congress participant → listing → F03 with hidden `congress_id`, free-text departure; existing client → external link, no login fields. Every form within 2–3 clicks, no prospect accounts. Forms (F04–F06): server-side validation, Turnstile, dedup, privacy-notice version stored, send log, email fallback, admin-only recipients per activity, POST-only, no PII in URLs or analytics. CRM (option, 6 h): outbound webhook after durable save, lookup-by-email upsert, 3 retries + dead-letter + resend, pinned API version; forms pass with it off. Measurement (H1–H4): CTA clicks, form start/submit/error, searches, listing views, account requests, client-area clicks, with source/page/activity, via a first-party beacon (Cloudflare Web Analytics has no custom events). Claims register (claim, source, page, ASSET OK + date) signed before J5. L0 deliverables: CMS/versions/extensions sheet, DNS/TLS inventory, signed account-owner register, crawl inventory, forms/trackers/Search Console list, Lighthouse baseline on 5 pages + legal/cookie check, keep-or-replace recommendation, one workshop (≤ 2 h) and 5 journey maps. Governance: RACI, change requests with cost/schedule/security/SEO impact fields, no DNS change without written go; every licence and third party listed with cost and payer.

What the client already asked (seven clarifications, 31 Oct; my reply committed to):

- Standard open-source stack, maintainable by another developer from repo + docs; a fixed list of editable section types and a clear line on what stays with a developer.
- Repo in an organisation in ASSET's name, full handover with rights, admin guide, runbook, export ASSET can run, a defined transfer package.
- 2 revision rounds per design and content stage; a prototype table marking every visible element included / optional / illustration only.
- A congress spreadsheet template with dry-run validation and rejection report; no event research by us.
- Fixed price for core, monthly plan with measured commitments, hourly rate for changes; free correction of any in-scope T01–T15 failure.
- Wondermiles: link at launch, feasibility study, integration quoted afterwards.

I also sent 30 questions; the defaults that shape the design: one shared enquiry mailbox (Q15); no trackers carried over (Q7); up to 300 congresses in my template (Q17); no fare code or wording until GM&E is confirmed in writing (Q18/20); past congress stays as past edition, form off (Q21); "Client login" button to the Traveldoo URL (Q23); IdP-or-OTP-plus-second-factor login (Q26); EU database (Q27); two editors, only Veena and management see GM&E codes (Q28); support Mon–Fri 9–18 Paris, back within 8 business hours (Q30).

3. What I have vs what I must build

My workspace splits deterministic scripts (tested) from the AI layer (routing and drafting only). Reusable pieces: an Astro 5 + Cloudflare template (CSP/HSTS headers, FR-default i18n, a11y baseline, KV rate limit, health endpoint, Vitest + Playwright + acceptance gate, CI); a contracts-first pattern with `--mock` adapters and a draft → review → approved pipeline; a static-site validator; a Worker form-intake pattern; pre-commit/pre-push SAST hooks; a screenshot-reading eye-review gate. Prior builds (anonymised): a public job board with listings, filters and a 3,047-check validation

suite; two live bilingual FR/EN sites with forms, moderation and a GDPR request flow; an approval pipeline with an R2 preview worker. **No travel or MICE reference.**

The concept proves front-end craft only: functional suite 65/65 (28 Oct); site_check pass on 4 pages × desktop/Pixel 7/iPhone 13/reduced motion; axe 0 violations; ≈ 108 KB bundle, zero third-party JS. Limit: I couldn't screenshot `*.pages.dev` from the sandbox, so live checks were HTTP 200, CSS hash and CSP header only.

Capability	Status	Lift path	Est. h (new work)
Static site, FR default, hreflang-ready; security headers	EXISTS	Scaffold template; tighten CSP for Console	—
Forms: validation, Turnstile; consent + GDPR DSR flow	EXISTS	Reuse; port DSR from KV/Supabase to D1	—
Structured data, sitemap, robots, canonicals	EXISTS	Add `Event` schema	—
Durable save + two-provider email fallback	PARTIAL	KV save exists; add D1, `send_log`, Brevo → Resend, retry queue	in forms
Redirects	PARTIAL	Generated 302 maps today; switch to 301, add generator + chain test	8
Listings with filters	PARTIAL	Job-board pattern; add period filter, search index	in catalogue
Approval pipeline	PARTIAL	Port to D1 state machines	in catalogue
Admin auth	PARTIAL	Basic Auth today → Access + 5 roles + MFA + break-glass	10
Monitoring	PARTIAL	Health endpoint exists; add external probes, status page, dead-man alarm	1.5
AI ingestion (L4)	PARTIAL	Model routing exists; queue, eval set, pinning new	option
Block editor, preview, publish trigger	MISSING	New "Console" package, ASSET as first tenant	14
Versions/restore, soft delete (30-day trash)	MISSING	`revision` snapshots	7
Audit log (12 months)	MISSING	Same-transaction writes, hash chain	3
D1 data layer	MISSING	Drizzle schema + migrations; **never used D1 before**	in modules
Encrypted vault	MISSING	AES-GCM, key in Worker secret, key ID per ciphertext	in M9
CSV import (dry run, dedup, report, batch ID)	MISSING	New	5
Enquiry back-office	MISSING	Inbox, statuses, owner, history, logged export, routing	12
Backups + restore drill	MISSING	Cron Worker + runbook + timed drill	3 + drill
Lighthouse and axe as CI gates	MISSING	Used ad hoc; wire in with thresholds	in QA
Crawl → URL inventory → redirect map	MISSING	New script + `--mock` test	in 8 above

Capability	Status	Lift path	Est. h (new work)
GM&E leak scanner	MISSING	Over all public output, seeded canary	2.5
Media library	MISSING	R2 upload, required alt + rights note, resizing	4
Event beacon + dashboard	MISSING	First-party, no cookie, no IP	3.5

The largest unmeasured line is the Console (≈ 44 h, never timed on this stack). If I spike one thing first, it's the block editor + publish-rebuild loop. Internal reviewers' standing concerns: 44 h for a block editor with versions, media and preview is optimistic; Console UX and the MICE brief need testing with real users; single-vendor concentration. Is "40% proven" honest, and would you buy off-the-shelf for any MISSING row?

4. Design

Domain model. Two D1 databases: `public_db` (content, catalogue, enquiries, events; readable by build and form Worker) and `vault_db` (GM&E; bound only to the admin Worker). ULIDs; every mutable table has `created_at/updated_at/deleted_at/created_by/updated_by`.

```
public_db
 user(id, email, display_name, roles[], active, last_login_at)
 page(id, slug, locale{fr|en}, title, meta_*, template, status, published_at,
      approved_by, translation_of, human_translated, version)        slug unique per locale
 block(id, page_id, position, type, data_json, version)
   type ∈ {hero,text,image_text,cards,list,faq,cta,quote_claim,congress_strip,contact_doors}
 media(id, r2_key, mime, w, h, alt_text NOT NULL, rights_note NOT NULL, rights_expires_on)
 claim(id, text, source_url, page_id, approved_by, approved_on)       claims register
 congress(id, title, slug, discipline, country_iso2, city, venue, organiser, start_date,
          end_date, timezone, official_url, verified_on, language, editorial_status,
          visibility, fare_badge, next_edition_id, import_batch_id, version)
 enquiry(id, type{BT|MICE|CONG|SME_ACCOUNT|DEMO}, source_utm_json, landing_path,
         referrer_domain, company, contact_name, email, phone, payload_json,
         congress_id?, status, owner_id, privacy_notice_version, marketing_optin(_at),
         dedup_key, purge_after)
 enquiry_event · send_log(provider, recipient_hash, status, error) · recipient_rule
 revision(entity, entity_id, version, snapshot_json) · audit_log(actor, action, entity,
         ip_trunc, prev_hash) · event(name, path, activity, utm_*, props_json, day)
 import_batch(rows_total/ok/rejected/flagged, dry_run, report_r2_key) · setting(key,value)
vault_db
 authorisation(id, congress_id, application_date, channel, code_ciphertext, code_iv,
               key_id, evidence_r2_key, conditions, stage, approver_id, valid_from/to)
 stage_history(authorisation_id, from_stage, to_stage, actor_id, note, at)
```

`vault.congress_id` refers to `public_db` by value only; no code path the build or form Worker can run joins across.

State machines.

Machine	States and transitions	Guards / rules
Editorial (pages, congresses)	draft → in_review (contributor+) → published (editor+); return to draft or unpublish without data loss; published → archived → restore to draft	Every transition writes `revision` + `audit_log`. Only `published` enters the build. EN publishes only if `human_translated`. Self-publish allowed (two-person rule optional: there are only two editors).

Machine	States and transitions	Guards / rules
GM&E (vault only)	detected → verified → application_to_prepare → application_submitted → code_received → issuance_authorised → approved_for_sale → archived	verified needs `official_url` + `verified_on`; submitted needs date + channel; code_received needs encrypted code + evidence + validity, approver/admin only; issuance needs named sign-off; approved_for_sale (approver) unlocks `fare_badge`; archived is read-only; step back = approver + mandatory note
Enquiry	new → contacted → qualified → quoted → won / lost; any → spam (purged at 30 days)	Each move logs actor, time, note. Duplicate (same email + type + congress within 24 h) appends an event to the first record.

Invariants (each has a test that must fail if broken).

#	Invariant	Enforced by	Test
I-1	No GM&E code, evidence or stage in any public byte (HTML, JS, JSON index, sitemap, CSV, API, error page)	Structural: no vault binding outside admin Worker. Scan: every stored code + a seeded canary searched across all build output and public API responses	T05; CI blocks deploy
I-2	No personal data in URLs, events or logs	POST-only; beacon property whitelist; search text dropped if it looks like email/phone; log redaction; truncated IP	T09 payload crawl; CI log grep
I-3	Nothing reaches prod except via the editorial machine	Build selects `published` only; no direct-publish API	T04
I-4	Enquiry durably stored before "thank you"	D1 write (KV fallback) then 200; email async via queue	T01 with D1 and email broken
I-5	No client-area password stored	No password column anywhere	T08 schema check
I-6	Every mutation attributable	`audit_log` in same transaction	Unit test per route
I-7	No fare badge without `approved_for_sale`	Badge write path checks vault stage	T05 dataset
I-8	Imports idempotent	Hard-dup key, batch ID, dry run writes nothing	Same file twice → 0 rows

Roles. Technical admin (me, later ASSET's developer); Editor (Veena, backup); Contributor (optional, drafts only); Commercial viewer (management, sales); Congress/fare approver (management, Veena). Roles are a set per user: Veena is Editor + Approver; the backup editor is Editor only (Q28). Matrix lives as data in `permissions.ts`, one middleware on every admin route, tested exhaustively (5 roles × every route × allow/deny). Access gates the hostname; the app maps the Access JWT email to roles.

Action	Admin	Editor	Contrib.	Viewer (mgmt)	Approver
Create/edit draft, submit, upload media	✓	✓	✓	—	—

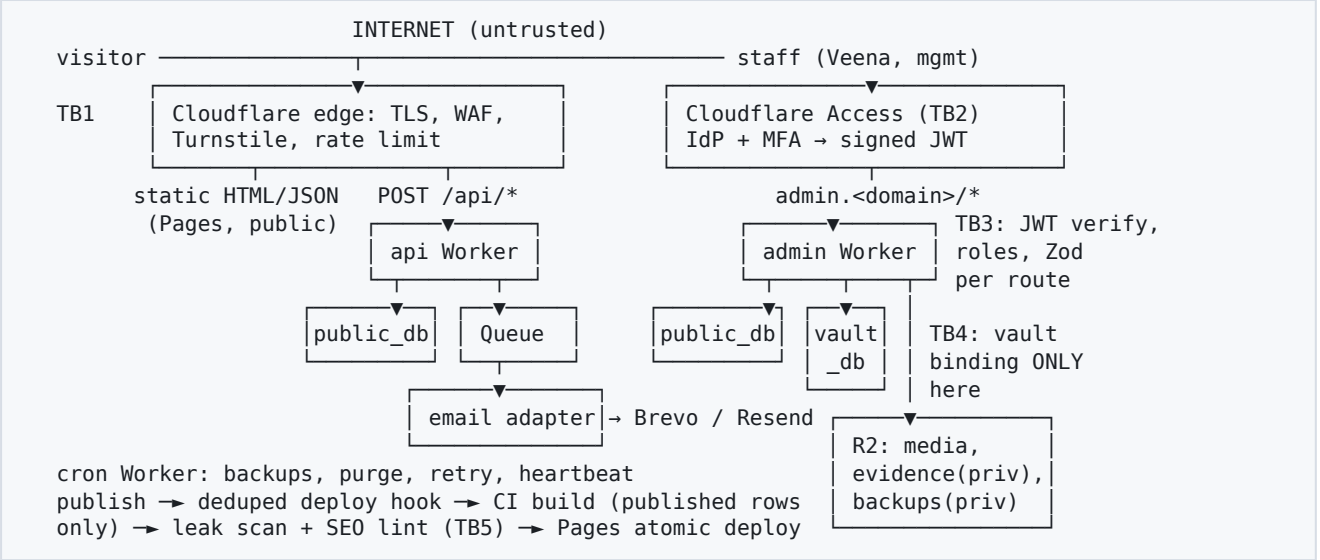
Action	Admin	Editor	Contrib.	Viewer (mgmt)	Approver
Publish/unpublish/archive; CSV import; enquiry status/owner	✓	✓	—	—	—
Restore revision / trash	✓	✓	own drafts	—	—
Read + export enquiries (logged)	✓	✓	—	✓	—
Public catalogue export	✓	✓	—	✓	✓
Read vault, advance GM&E stage, set fare badge	✓	—	—	—	✓
Hard delete; recipients, settings, users	✓	—	—	—	—
Read audit log	✓	own actions	—	—	vault only

CSV import. Schema v1 = RFP congress fields; ISO dates, ISO 3166 alpha-2, UTF-8, `;` / `,` auto-detected. Required: title, discipline, country, city, start/end date, official_url, verified_on, language. Coded errors (E01 missing, E02 bad date, E03 end before start, E04 bad URL, E05 unreachable URL, E06 bad country…). Hard duplicate (normalised title + start date + city) rejected; soft (same title, same year) flagged. Flow: upload → dry run → downloadable report → confirm → import as drafts with batch ID → bulk publish.

Retention (proposals, ASSET to approve): prospects 3 years after last contact (Open: verify against CNIL guidance); spam 30 days; audit/Access/send logs 12 months; raw events 13 months; vault until `valid_to` + agreed period; revisions all or last 50 (Open); won clients per ASSET's own policy; backups 30 days Time Travel, 30 nightly, 12 weekly. Export: one command/button → ZIP of every table (CSV + JSON) + media + checksummed manifest; vault exported separately, encrypted. DSR: search by email across enquiry tables, export or delete, log it.

i18n and SEO. French at `/` or `/fr/` (Open: decide from the crawl, today's URLs have no prefix); English under `/en/`, built, off until bought. Per-locale slugs linked by `translation_of`; self canonical; `hreflang` (fr, en, x-default) only when both are live. Migration: crawl → inventory (status, title, canonical, inlinks, GSC clicks) → per-URL decision (retain/merge/redirect/remove; ASSET approves priority URLs) → generated `_redirects` (301) → chain and no-blanket-to-home checks → staging test (each old URL → one 301 → 200) → cutover checklist → weekly Search Console + 404 report through J6. Intentional removals return 410. Staging noindex + behind Access. Congress pages emit schema.org `Event` (Open: check against Google's event policy). Past congress: banner, form off, link to next edition, indexable 12 months, then 301.

5. Architecture



Components. Pages (pre-built Astro HTML + JSON search index); three Workers from one repo (`api`: forms, beacon, health; `admin`: Console API behind Access; `cron`); D1 with EU jurisdiction set at creation, Time Travel 30 days; R2 (no egress); Access; Turnstile; Queues (email + rebuild dedup); Brevo primary (French), Resend fallback; GitHub org in ASSET's name with Actions + Renovate; UptimeRobot probes + status page (independent of Cloudflare); L4 only: OpenRouter, pinned model, schema-bound output, never publishes. TypeScript throughout; Zod at every boundary; Drizzle; Console UI in Preact or web components (Open, D3 in §10).

Boundary	Control
TB1 internet → edge	TLS, HSTS, CSP, WAF managed rules, Turnstile, per-IP rate limit on `/api/*`
TB2 internet → admin	Access policy by named email; IdP with enforced MFA; 12 h session
TB3 admin Worker → data	Verify JWT (aud + signature), email → roles, permission middleware, Zod
TB4 vault	Only admin Worker has `vault_db` + private R2 bindings; AES-GCM; approver/admin only
TB5 build → public	Build reads published rows only; leak scanner before deploy
TB6 Workers → third parties	Worker secrets; minimum data (no PII to AI; hashed recipients in logs)

Flows. *Enquiry:* POST → Turnstile → Zod → dedup key → D1 insert (KV if D1 errors) → 200 → queue → Brevo, else Resend, else flag + 15-min retry + Console banner → `send_log`. *Publish:* approve → state + revision + audit → deduped deploy hook (many presses = one build) → CI → leak scan + SEO lint → atomic deploy. *Import:* upload → validate + dedup dry run → report to R2 → confirm → transactional insert as drafts. *Authorisation:* approver advances stage → `stage_history` + audit; badge write checks stage. *Measurement:* cookie-free page views + beacon with whitelisted properties → `event` → daily aggregates. *Backup:* nightly export of both DBs → private R2 → weekly off-platform copy → heartbeat.

Environments, deploy, rollback. dev (Wrangler, local D1/R2, fake codes) · staging (`staging.` + `admin.staging.`, own D1/R2, seed data, Access, `X-Robots-Tag: noindex`) · prod. Same code, per-env bindings and secrets; PR previews against staging. Pages deploys are immutable with instant rollback; Workers versioned with rollback; CI deploys the three Workers in fixed order from one commit; migrations forward-only, expand → migrate → contract across two releases, so a partial deploy or code rollback never meets an incompatible schema. Cutover: DNS TTL lowered 48 h before, checklist, switch on written go, old host kept 30 days for revert.

Backups. L1 D1 Time Travel (minutes, 30 days) · L2 nightly SQL export to private R2, 30 copies (RPO 24 h) · L3 weekly off-platform copy of L2 + media, 12 kept, client-side encrypted · L4 git. Restore drill: fresh D1, import last night's dump, point a staging Worker at it, smoke suite, stopwatch; at J5 (T13) then monthly. **Never run on this stack.** Open: off-platform provider not chosen or priced.

Observability. UptimeRobot every 5 min on home, a congress page, `/api/health` (D1 read, queue depth, secret presence, build SHA) and admin reachability; status page; dead-man heartbeat from backup cron; Worker exceptions and failed jobs → one error channel (service/env/error/count); no-PII logs; send failures as a Console banner for Veena; monthly report.

Security. CSP `default-src 'self'`, no inline script, `frame-ancestors 'none'`, nosniff, strict referrer, minimal Permissions-Policy; HSTS (preload after stabilisation). No public admin; JWT re-verified in-app. Email OTP alone is one factor, so not MFA: default is ASSET's IdP with enforced MFA, else a supported IdP with TOTP/passkey (Open: which IdP ASSET uses). Scoped API tokens, branch protection, SAST pre-push, `npm audit`, Renovate, critical patches within 2 business days, ZAP baseline at J3/J5. Subprocessors: Cloudflare (DPA + SCCs/DPF), Brevo (FR), Resend (US), UptimeRobot, GitHub.

Failure	Fallback	Detection
D1 unavailable	Write to KV, replay job; user still gets "thank you"	health, error channel
Brevo fails / both fail	Resend / saved + banner + 15-min and daily retry	`send_log`
Access outage (12 Jun 2025, ~2h28)	Public site unaffected; break-glass CLI	probe
Cloudflare global incident (18 Nov 2025, ~2h10)	None on-platform; status page; excluded from SLA	external probe
Bad deploy / bad migration	Instant rollback / forward-fix or Time Travel to CI-recorded bookmark	synthetic, staging migration test
Accidental deletion	Trash 30 days + revisions	—
Code typed into free text	Leak scanner fails build	CI
Rebuild storm / spam wave	Deduped hook / Turnstile + rate limit + spam status	queue depth, counts
Me unavailable	Runbook for a stranger; everything in ASSET's name; backup developer **not yet arranged**	—

Why a modular monolith, and why not Directus or microservices. Five users, ≈ 300 listings, low traffic: separate services add network failure modes, deploy coordination and monitoring for no scaling benefit. One repo, three Worker entry points, shared typed modules, adapters at the edges. *Directus + same Astro front end:* mature editor, roles, revisions, media; maybe −25 to −30 h on the Console; but a server + Postgres (≈ €10–30/month, estimate), its patching and uptime become mine, ≈ 16 h setup, the vault becomes a permission setting rather than a structural split, and a second runtime to hand over. *WordPress + ACF* (keep current): cheapest for editors, but plugin surface, PHP hosting, GM&E isolation harder to prove; L0 must assess it honestly. **Directus is the call I most want challenged.**

Things I've thought about; check me. Platform limits from Cloudflare docs as I read them on 31 Oct; re-verify all at J0.

Topic	Position	Status
Load	≤ 5 staff, ≈ 300 listings, low thousands of visits/day, tens of enquiries/day	Open: guesses; get 12 months of analytics at L0
D1 size/concurrency	Workload ≈ MBs vs 10 GB per DB (Paid); one serial primary, fine at tens of writes/day; public reads hit static output, not D1	Re-verify
Workers CPU for import	300 rows ≪ 1 s CPU (30 s default on Paid); cap 5 MB / 2,000 rows; D1 `batch()` chunks under one batch ID so a failed chunk rolls back the import	Caps are my proposal
Media pipeline	Upload via admin Worker to R2: type sniffed, 10 MB cap, EXIF stripped; responsive variants at build time (sharp in CI) rather than Image Transformations	Open: image counts at L0
Search, pagination	Build emits JSON index; browser filters and paginates (20/page). Console uses SQL `LIMIT/OFFSET` + indexed filters; FTS5 only past ≈ 5,000 rows	Decided
Caching/freshness	No ISR; fully static; deduped rebuild per publish; short edge cache on HTML, immutable hashed assets; freshness = build time, target < 5 min	Measure in skeleton
Draft preview	No per-draft builds; Console renders drafts server-side with the same Astro components, behind Access, noindex	Open: fits Console hours?
Editor conflicts	Optimistic locking on `version`; stale save → 409 showing the other change; no co-editing	Decided
Form rate limits	Turnstile + per-IP limit (e.g. 10 posts / 10 min) + body size cap	Tune on staging
Access session	12 h; step-up re-auth for vault actions if the IdP supports it; revoke by removing email + sessions	Open: depends on IdP
Migration rollback	Forward-only; applied first to a staging copy of prod; bookmark recorded by CI	Decided
Secret rotation	Inventory (vault key, email keys, Turnstile, deploy hook) with owner and steps; rotate at handover and yearly; `key_id` per ciphertext so old and new vault keys coexist	Decided
Backup encryption	R2 at rest; off-platform copy encrypted client-side (age/GPG), key with ASSET admin and me; vault dump separately encrypted	Open: provider
Audit-log tamper evidence	Append-only in code, each row hashes the previous, exported nightly off-platform; detects silent edits, not tamper-proof against a platform admin	Decided
GDPR DSR	Access/rectify/erase within one month; erasure reaches backups by expiry (30 days / 12 weeks), stated in the privacy notice	Open: ASSET's DSR contact
Test data	Fictional listings and fake codes; staging on seed data; anonymised prod copy only with approval; no real codes outside prod	Decided

6. Build plan and tests

Contracts first (week 1). A frozen `CONTRACTS.md`: C0 scope (prototype table, section types, counts, T01–T15 annex) · C1 schema + migration policy · C2 every route (method, path, role, Zod in/out,

errors) · C3 state machines as typed tables · C4 invariants with tests · C5 adapters (`EmailProvider`, `Store`, `Clock`, `AIProvider`), each with a mock · C6 CSV v1 · C7 beacon events · C8 ops commands. Every AI-assisted session is held to it.

Walking skeleton (weeks 1–2), on staging: one Astro page from one block → F01 → D1 → queue → email adapter → Console behind Access listing the enquiry → publish triggers rebuild → nightly backup → restore into fresh D1 → CI with leak scanner, axe and Lighthouse. It measures the unmeasured: rebuild time, Access/JWT path, export size and restore time, and my real Console speed. The estimate is re-based at J1.

#	Module	Content	h
M1	Audit (L0)	Crawl tool, inventory, account register, baseline, workshop, architecture doc	12
M2	Design system	Tokens, ≈ 15 components, 8 templates, mock-ups 375/1440, HTML prototype	24
M3	Public pages	≈ 20 pages + 3 legal	20
M4	Forms	F01–F03, validation, Turnstile, dedup, durable save, email fallback	12
M5	Enquiry back-office	Inbox, statuses, owner, history, logged export, routing	12
M6	Measurement + GDPR	Beacon, dashboard, consent, legal, DSR	8
M7	Console core	Access + roles, block editor, media, revisions, soft delete, audit log, publish	44
M8	Catalogue public	Index, filters, pagination, listing, past-event rule, `Event`, sitemap	14
M9	Catalogue admin + vault	Congress form, import, exports, both state machines, encryption, leak scanner	18 (21 detailed)
M10	SEO migration	Redirect generator, chain test, Search Console	12
M11	Infrastructure	Envs, CI, backups, drill, monitoring, break-glass	12
M12	QA + acceptance	T01–T15, manual a11y, CWV lab, ZAP, report	22
M13	Handover	Guide, runbook, inventory, 2 trainings, transfer package	10
M14	Project management	Weekly updates, milestone packs, change control	18
	Core		**238 + 48 contingency = 286**

Tier	Tool	Covers	When
Unit	Vitest	State machines, permission matrix, dedup, CSV parser, redirect generator, encryption round-trip	Every push
Integration	Vitest + Miniflare/local D1	Routes on real local D1; adapters mocked and real	Every push
E2E	Playwright	Journeys; Console flows; **T01–T10** automated (T01/T02 with email deliberately broken; T03 on 300 rows × 10 queries; T04 draft → 404 + absent from sitemap/index; T10 every priority URL → one 301 → 200)	Every preview

Tier	Tool	Covers	When
Leak	Scanner + canary	**T05**: 0 matches; canary found	Every build, blocks deploy
A11y	axe + NVDA/VoiceOver script	**T11**: 0 serious; 5 journeys manual	Preview; manual J3, J5
Performance	Lighthouse CI per template	**T12**: LCP ≤ 2.5 s, CLS ≤ 0.1, TBT as INP proxy; 4-width screenshots + eye review	Every preview
Restore	Script + stopwatch	**T13** ≤ RTO, smoke green	J5, monthly
Export / editor	Spreadsheet check; observed session	**T14** columns match doc (partly manual); **T15** Veena alone with the guide (manual)	J4, J5
Security	SAST, `npm audit`, ZAP	No HIGH/CRITICAL	Push; ZAP J3, J5
Live	Front-door probe	5 consecutive green days before "live"	From cutover

CI gates (all must pass to merge): typecheck → lint → unit → integration → build → leak scanner → SEO lint (one H1, titles, canonicals, hreflang, no internal status words) → preview deploy → E2E → axe → Lighthouse → front-door on preview. Main protected; prod only from tagged releases.

Done when	
J0	RACI, access inventory, dated schedule, repo + Cloudflare in ASSET's name, approval
J1	Crawl inventory with decisions, account register, baseline, architecture doc, risk register, **skeleton on staging**, estimate re-based
J2	8 templates at 375/1440, prototype, design-system page, claims register started, ≤ 2 rounds
J3	All L1 pages served from Console content; T01–T02; events verified; axe and Lighthouse green; **Veena edits a page alone**
J4	300 listings (or ASSET's file + rejection report); T03–T08; vault + leak test green
J5	Redirect map approved, T10; T01–T15 pass with evidence report; training 1; restore timed; rollback plan; written go; DNS cutover
J6	4 weeks of checks and fixes; outstanding list closed; training 2; handover complete with secrets rotated

Handover is a product. Media upload with required alt/rights; self-serve CSV dry run (Veena imports 10 rows); one-click export (T14); restore runbook + drill record (T13); help panel on every Console screen; illustrated guide generated from Console screenshots (Veena follows it in T15); two recorded trainings, the second 4 weeks after launch; runbook "for a stranger at 6 a.m." (deploy, rollback, restore, export, rotate secrets, add user) tested by someone not involved; signed account inventory; transfer package via password manager. Backups, drills, monitors and dependency PRs run on schedules, not my memory: if I stop, the site keeps running on ASSET's accounts.

7. Effort, timeline, price

Hours (estimates by analogy, not measured): two independent counts, ≈ 220 and 238 core; planning figure 265–286 with 20% contingency. Biggest swings: design 16 vs 24, PM 25 vs 18, QA 16 vs 22. Options: English 8 h · CRM connector 6 h · Wondermiles feasibility 4 h / SSO 12 h · AI ingestion 16 h. Included: up to 20 pages from ≈ 8 templates + 3 legal; up to 300 imported listings; copy from ASSET, light edit; 2 revision rounds per stage; 2 trainings; 4-week stabilisation. Translation excluded.

Calendar (start Mon 16 Nov if signed by 13 Nov; approvals within 3 working days; no launch 21 Dec–1 Jan). Lean ≈ 35 h/week; conservative ≈ 22 h/week plus realistic client delay. I intend to contract the conservative dates. 4–5 weeks would only work by cutting the Console to text/images and GM&E to statuses only.

	J0	J1	J2	J3	J4	J5 cutover	J6 ends
Lean	20 Nov	2 Dec	16 Dec	15 Jan	22 Jan	wk of 25 Jan	26 Feb
Conservative	20 Nov	2 Dec	8 Jan	5 Feb	19 Feb	12 Mar	9 Apr

Price option	Build	Monthly plan (12-month min.)	Build rate on 265 h	3-year total HT
Lean	€4,000	€600	≈ €15/h	€25,600
Recommended	**€7,500**	**€600**	≈ €28/h	**€29,100**
Fair solo	€9,500–12,000	€600–750	≈ €36–45/h	—
Small Paris agency	€18,000–25,000	€750–900	≈ €68–94/h	€45,000–57,400

Market evidence (mostly search summaries; verify before quoting)	Figure
Paris full-stack freelance day rate (Malt, TJMetre, Freeland 2026)	≈ €520–600/day; 265 h ≈ 38 days ≈ €21k
Small agency, 5–15 people (La Fabrique du Net)	€550–800/day
Custom site with back-office and APIs (Agence2web) / medium web app (Seedweb)	from €8,000 / €20,000–50,000
WordPress maintenance (Make Different, Ellebay) / out-of-contract hourly	€100–350/month / €60–150

The plan covers hosting and tools (accounts in ASSET's name, paid by me), security updates, backups and drills, monitoring, up to 5 h of changes a month, Mon–Fri support, monthly report. **Running costs:** Workers Paid $5 (≈ €4.3, includes D1, Queues, Time Travel); D1, R2, Access (≤ 50 users, unverified), Turnstile, Web Analytics €0 at this size; Brevo €0–9; Resend €0; UptimeRobot €0–10; domain ≈ €9–32/year; L4 AI €5–20; off-platform backup Open. Total ≈ €5–15/month, up to ≈ €25 with paid monitoring. Is €7.5k so low it reads as risk? Would you go to €9.5k+?

8. Risk and complexity

Complexity = Σ effort weight × rating (1 trivial … 10 novel/hard to test). Ratings are my judgement, reconstructed to match the score I first computed.

Module	Weight	Rating	Contrib.	Why
Public pages	0.15	3	0.45	Done before

Module	Weight	Rating	Contrib.	Why
Forms + dedup + fallback	0.10	6	0.60	Async email, two providers
Enquiry back-office	0.08	5	0.40	CRUD + history
Console editor, media, versions	0.22	8	1.76	New; non-developer UX; rebuild loop
Roles, MFA, audit	0.10	7	0.70	Access JWT + matrix
Catalogue public / admin + import	0.08 / 0.10	4 / 7	0.32 / 0.70	Pattern exists / dedup, idempotency
GM&E vault + workflow	0.07	8	0.56	Encryption, isolation, leak proof
SEO migration / infra + backups	0.05 / 0.05	7 / 7	0.35 / 0.35	Unknown URL count / restore never run on D1
Total	1.00		**≈ 6.2/10**	

Confidence that J5 lands on the contracted date and scope: $P = \Pi\ (1 - r_i)$, r_i = residual chance (after mitigation) that risk *i* breaks it. Independence is optimistic: R1 and R2 correlate through the calendar. Doesn't cover losing the bid or post-launch defects.

#	Risk	Mitigation	r cons.	r lean	Your r
R1	Client inputs late	Defaults, day-for-day shift, weekly written chase	0.08	0.14	
R2	Me unavailable (single point of failure)	Conservative calendar, runbook, repo in client's name; no backup dev yet	0.07	0.11	
R3	Console overrun	Fixed section types; skeleton measures speed; scope-cut list	0.03	0.08	
R4	Site access / DNS / domain blocked	Ask at J0; parallel build	0.03	0.05	
R5	Vault flaw or leak	Structural isolation, encryption, canary scanner, role tests	0.01	0.01	
R6	SEO migration loses a critical URL	Crawl + GSC, chain test, T10, weekly checks	0.02	0.03	
R7	Platform limit found late	Skeleton exercises every binding	0.01	0.02	
R8	Notifications fail in prod	Two providers, durable save, banner	0.01	0.01	
R9	Acceptance dispute	T01–T15 frozen; defects only against tests	0.01	0.03	
R10	Client CSV quality	Template, dry run, rejection report	0.01	0.03	
R11	Restore fails at drill	Drill in skeleton and J5; Time Travel	0.01	0.02	
R12	Scope creep	Change control	0.01	0.04	
	P		**≈ 0.735**	**≈ 0.552**	

So roughly 3-in-4 on the conservative calendar, about even on lean. The two biggest residuals aren't engineering. Would you use a reference-class forecast instead? Is the Console's 22% × 8 right?

9. KPIs per stage

Every KPI has a method and an owner (me unless stated). "Baseline" means measured, not targeted.

Stage	KPI → target	Method / tool
J0	Access inventory 100% (domain, DNS, hosting, email, GA, GSC, GBP) with owner; accounts in ASSET's name 100%; schedule approved	Account register; email
J1	100% of crawled URLs have a decision; 100% of URLs with ≥ 1 GSC click in 16 months mapped; lab CWV on 5 pages; tracker + form counts; skeleton measures (rebuild, restore, Console velocity); estimate re-based vs 286 h	Crawl tool, GSC export, Lighthouse, network crawl, CI logs
J2	8/8 templates approved; ≤ 2 rounds; every form ≤ 2–3 clicks from home; claims register lists every claim (Veena)	Approval email, click-count table
J3	23/23 pages; T01–T02 green; axe 0 serious; lab LCP ≤ 2.5 s, CLS ≤ 0.1, TBT ≤ 200 ms per template; 8 event types fire, 0 PII; Veena edits alone	Playwright, axe, Lighthouse CI, payload grep, observed session
J4	Imported/rejected/flagged counts with codes; 100% hard dups rejected; leak 0 + canary found; T03–T08 100%; role matrix 100%	Import report, scanner, suite
J5	T01–T15 100% with evidence; priority redirects 100%, ≥ 95% of all URLs implemented, 0 chains, 0 blanket-to-home; RTO ≤ 8 bh; Lighthouse Perf ≥ 90, A11y ≥ 95, SEO ≥ 95; ZAP 0 high; 0 launch blockers (management)	Acceptance report, redirect test, drill, ZAP
J6	Uptime ≥ 99.5%; no new 404s on mapped URLs; enquiries/day baseline by activity (Veena); Veena's first solo publish ≤ 3 working days after launch; 0 open items; 5 green front-door days	UptimeRobot, GSC weekly, D1 counts, audit log
Monthly	Availability ≥ 99.5% excl. provider-wide incidents; 100% nightly backups, 0 missed heartbeats; drill passed + timed; changes within 5 h delivered in agreed days (Open: set); critical patches ≤ 2 business days; enquiries by activity with source; field CWV if CrUX publishes	Probe, cron log, drill log, tickets, dashboard, CrUX

Which of these is vanity, and which business KPI is missing? Is 99.5% honest on Cloudflare with no platform SLA? Is TBT a fair INP proxy?

10. Open decisions and scoring sheet

#	Decision	My lean	What would change it
D1	Price: €4k / €7.5k / ≥ €9.5k	€7.5k + €600 × 12	Evidence procurement discounts low bids
D2	Console: build vs Directus	Build	Credible estimate the custom Console exceeds ≈ 70 h, or vault isolation equally provable in Directus
D3	Console UI: Preact vs web components	Undecided	Your view on third-party maintainability
D4	D1 (EU) vs managed EU Postgres	D1	D1 maturity, export, limits, lock-in
D5	5-working-day deemed acceptance	Keep, worded politely	Evidence it costs the bid

#	Decision	My lean	What would change it
D6	Off-platform backup store	Choose before J1	Your recommendation
D7	Backup developer	Name one before signature	Whether the bid is viable without one
D8	French at `/` or `/fr/`	Decide from crawl	Old URL structure

Four open-ended asks: the single change that most raises on-time delivery; the one that most raises the chance of winning; anything you think is **wrong**, not just risky; anything you'd refuse to sign off.

§	Section	Score 1–10	Comment
2	The job		
3	What I have vs must build		
4	Design		
5	Architecture		
6	Build plan and tests		
7	Effort, timeline, price		
8	Risk and complexity		
9	KPIs		
10	Open decisions		
—	**Overall: would you fund this plan?**		

Name: _____ Date: _____ Time spent: ____ h

Appendix: glossary and sources

Glossary. MICE: meetings, incentives, conferences, exhibitions. GM&E: Air France–KLM Global Meetings & Events, per-event codes giving attendees discounted fares. Wondermiles / Traveldoo: corporate booking tools. D1: Cloudflare's hosted SQLite (Time Travel = point-in-time restore). R2: object storage. Access: Cloudflare Zero Trust login gateway. Turnstile: CAPTCHA alternative. RPO/RTO: max data loss / max restore time. LCP/INP/CLS: Core Web Vitals; TBT: lab proxy for INP; CrUX: Chrome field data. DSR: GDPR data-subject request. CNIL: French data regulator. DPA/SCCs/DPF: processing agreement / EU clauses / EU–US framework. HT/TTC: excl./incl. VAT. ZAP: OWASP scanner.

Sources. ASSET RFP v0.4 EN, 28 Oct 2026 (restricted); client site fetched 28 Oct 2026. Cloudflare (checked 28 Oct 2026): Workers pricing

https://developers.cloudflare.com/workers/platform/pricing/ · Pages limits https://developers.cloudflare.com/pages/platform/limits/ · D1 pricing https://developers.cloudflare.com/d1/platform/pricing/ · Time Travel https://developers.cloudflare.com/d1/reference/time-travel/ · D1 location https://developers.cloudflare.com/d1/configuration/data-location/ · R2 https://developers.cloudflare.com/r2/pricing/ · Zero Trust limits https://developers.cloudflare.com/cloudflare-one/account-limits/ · Turnstile https://developers.cloudflare.com/turnstile/plans/ · Web Analytics https://www.cloudflare.com/web-analytics/ · DPA https://www.cloudflare.com/cloudflare-customer-dpa/ · incidents https://blog.cloudflare.com/cloudflare-service-outage-june-12-2025/ , https://blog.cloudflare.com/5-december-2025-outage/ . Email/monitor: https://www.brevo.com/products/transactional-email/ · https://resend.com/pricing · https://uptimerobot.com/pricing/ . Market: https://www.malt.fr/t/barometre-tarifs/tech/developpeur-backend/developpeur-fullstack · https://tjmetre.fr/barometre · https://barometre.freeland.com/tjm/developpeur · https://www.lafabriquedunet.fr/agences/pages/agences-developpement-web/tarifs · https://www.agence2web.com/tarifs-site-web/ · https://seedweb.fr/prix-site-internet/ · https://ellebay-digital.com/blog/cout-maintenance-site-web-2026 · https://makedifferent.fr/blog/cout-maintenance-site-web/ . **Not sourced** (Open): CNIL retention period, Google Event policy, Access ≤ 50 free users, the reconstructed complexity/risk tables.